



Secure Software Design

Assignment 02 **Secure UML Design and Threat** **Modelling of Project**

Submitted by: Umar Farooq, Waseem Sajjad and Faisal
Yaseen

Roll number: 23I-2053, 23I-2030 and 23I-2018

Table of Contents

Introduction	3
Requirements Specification (FR ↔ Security NFR Table).....	3
Use Case and Misuse Case Diagrams.....	4
Secure Sequence Diagrams.....	5
Secure Login.....	5
Device Data Transmission	6
Threat Detection Process.....	7
Device Isolation Response	8
Secure Statechart Diagrams.....	9
Admin Authentication.....	9
IoT Device.....	11
Detection Engine	12
Data Flow Diagrams (DFDs).....	13
Level 0	13
Level 1	13
Level 2	14
Level 2 - Traffic Analysis	14
Authentication	15
DFD - Device Registration	16
Dashboard.....	17
Level Response.....	18
Threat Modelling.....	18
PASTA Methodology (7 Stages).....	18
Stage 1: Define Business Objectives & Security Goals	18
Stage 2: Define Technical Scope	19
Stage 3: Application Decomposition	19
Stage 4: Threat Analysis (Attacker Profiles)	19
Stage 5: Vulnerability & Weakness Analysis	19
Stage 6: Attack Modeling & Simulation	20
Stage 7: Risk Analysis & Management	20
STRIDE Threat Analysis Table.....	20
DREAD Risk Scoring.....	21
Summary.....	21

Introduction

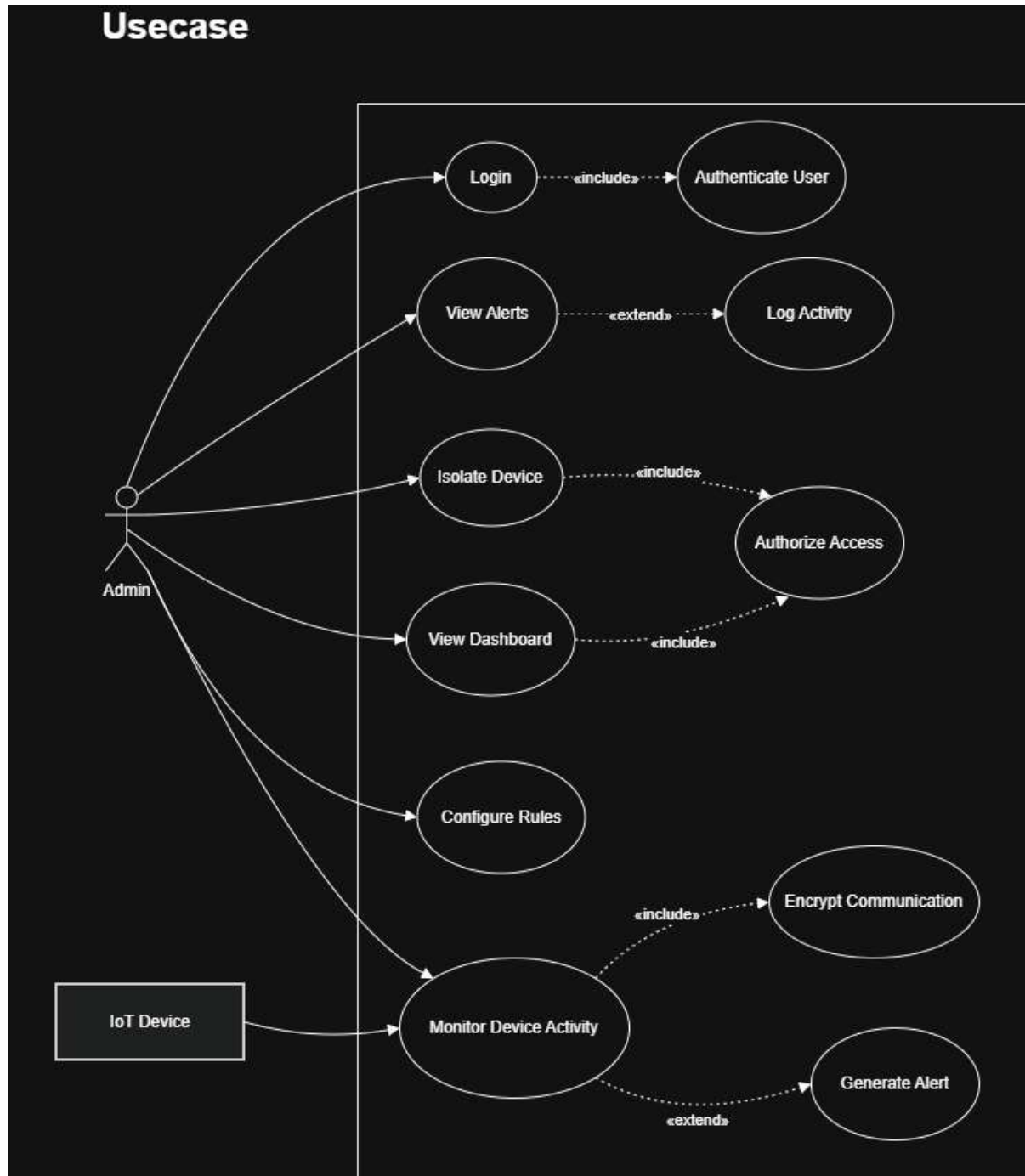
This report presents the secure design and threat modelling of an IoT Botnet Detection and Response System. The system focuses on monitoring IoT devices, detecting malicious behavior, and responding to potential botnet attacks. Secure UML techniques and structured threat modelling approaches are applied to ensure a robust and secure system design.

Requirements Specification (FR ↔ Security NFR Table)

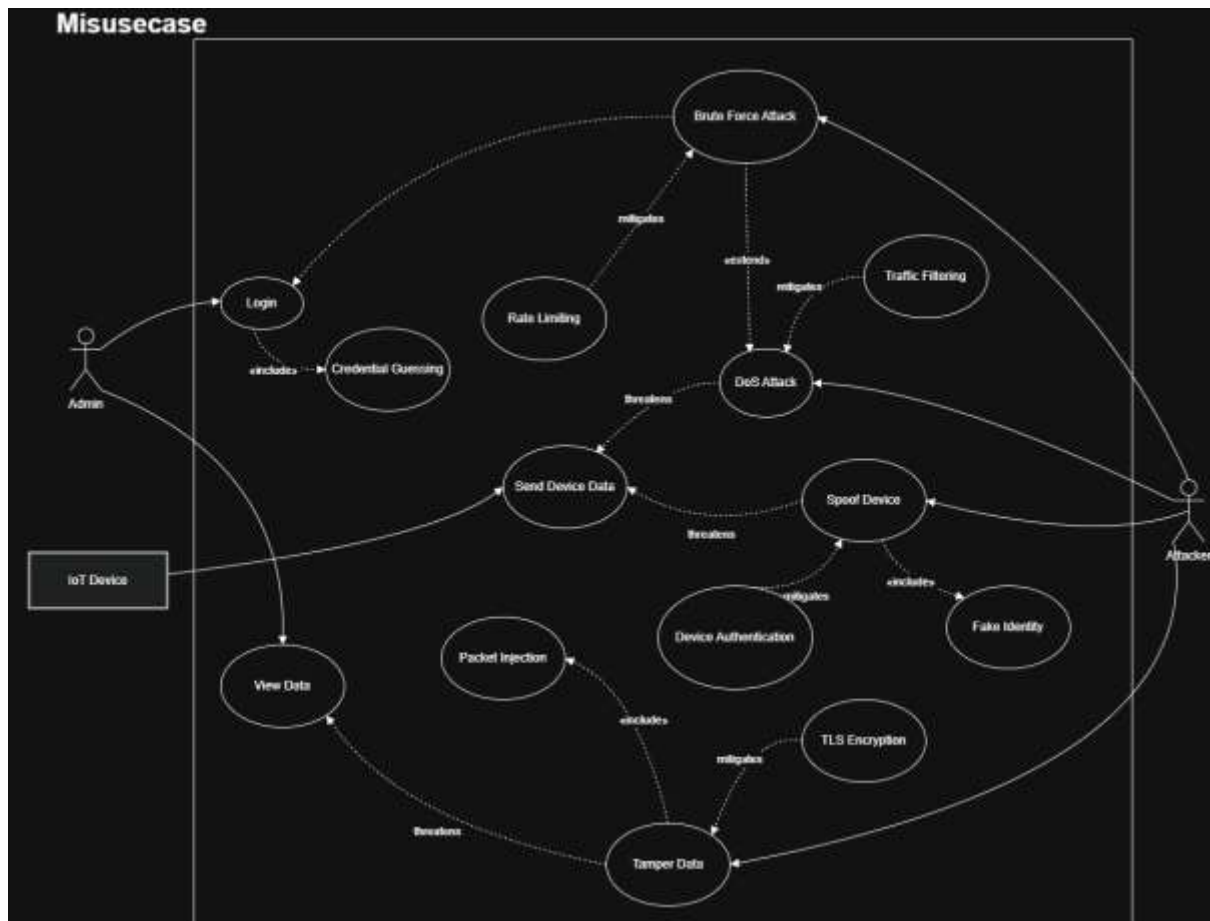
Functional Requirement (FR)	Security Non-Functional Requirement (NFR)
FR1: User (Admin) can register an account	NFR1: Registration data must be transmitted over TLS/HTTPS to ensure confidentiality
FR2: Admin can log in to the dashboard	NFR2: Passwords must be securely hashed using bcrypt/Argon2 and protected against brute-force via rate limiting
FR3: Admin can view IoT device data	NFR3: Role-Based Access Control (RBAC) must ensure only authorized admins can access device data
FR4: IoT devices send network traffic data to server	NFR4: All device-server communication must be encrypted using TLS and authenticated via API keys or certificates
FR5: System monitors device behavior continuously	NFR5: Monitoring system must ensure high availability (99.9% uptime) and resilience against DoS attacks
FR6: Detection engine analyzes traffic patterns	NFR6: Data integrity must be ensured using hashing mechanisms to prevent tampering of traffic data
FR7: System generates alerts for suspicious behavior	NFR7: Alerts must be securely logged and protected against unauthorized modification (tamper-proof logging)
FR8: Admin can view alerts and logs	NFR8: Logs must be access-controlled and encrypted at rest to ensure confidentiality and integrity
FR9: System can isolate or block compromised devices	NFR9: Authorization checks must ensure only privileged admins can trigger response actions
FR10: Admin can configure detection rules	NFR10: Input validation must be enforced to prevent injection attacks (e.g., rule manipulation)
FR11: System stores device and traffic data	NFR11: Data must be encrypted at rest using AES-256 or equivalent encryption standard
FR12: System supports multiple devices simultaneously	NFR12: System must handle concurrency securely and prevent resource exhaustion (rate limiting, throttling)
FR13: Admin session management	NFR13: Secure session management with timeout, token rotation, and protection against session hijacking
FR14: System logs admin actions	NFR14: Logs must support auditing and non-repudiation (timestamped, immutable records)

Use Case and Misuse Case Diagrams

This diagram shows how the Admin interacts with the IoT botnet detection system. It highlights key functionalities such as login, monitoring device activity, viewing alerts, configuring rules, and isolating compromised devices. Security-related actions like authentication, authorization, and encrypted communication are included to ensure secure system usage.



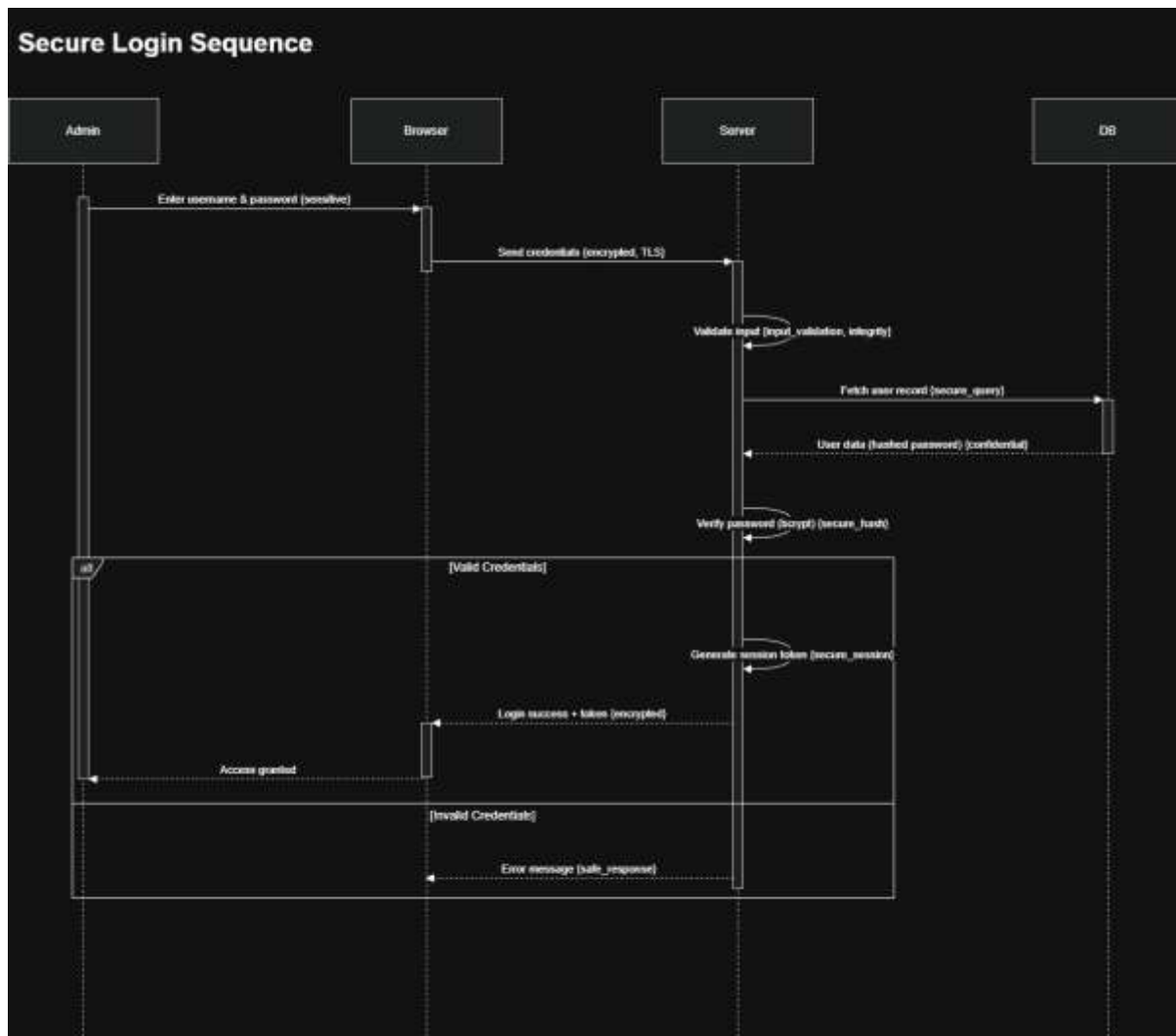
This diagram illustrates potential attacks by an Attacker (e.g., brute force, spoofing, DoS, data tampering) against the system. It also shows how security mechanisms like rate limiting, TLS encryption, traffic filtering, and device authentication mitigate these threats, emphasizing the system's defensive design.



Secure Sequence Diagrams

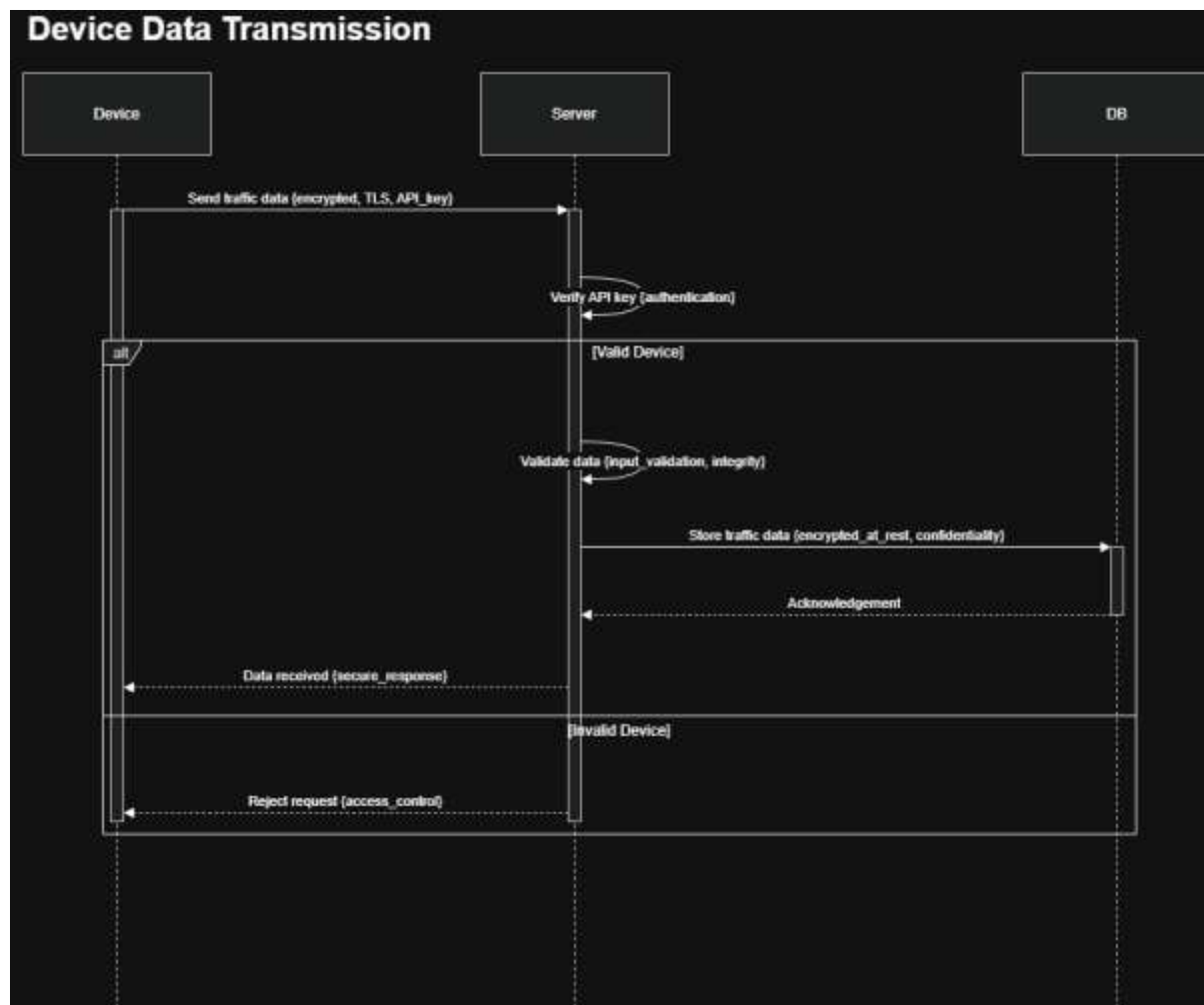
Secure Login

This process ensures secure user authentication by using TLS to protect credentials in transit and hashing (bcrypt) to protect passwords in storage. The server validates inputs and generates a secure session token upon successful login. Rate limiting is applied to prevent brute-force attacks.



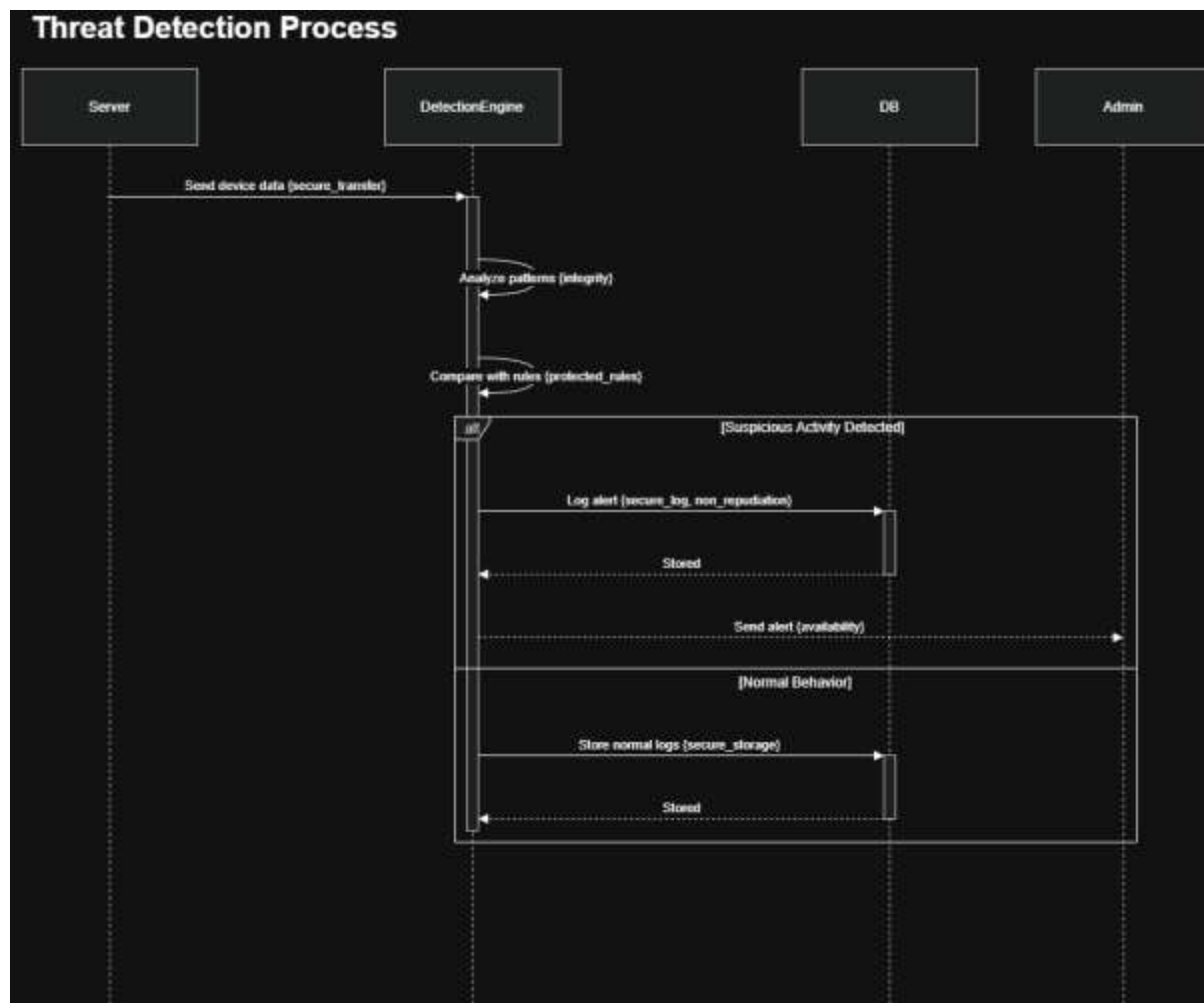
Device Data Transmission

This sequence secures IoT communication using TLS encryption and API key authentication. The server validates incoming data and stores it with encryption at rest. Integrity checks ensure the data is not altered during transmission or storage.



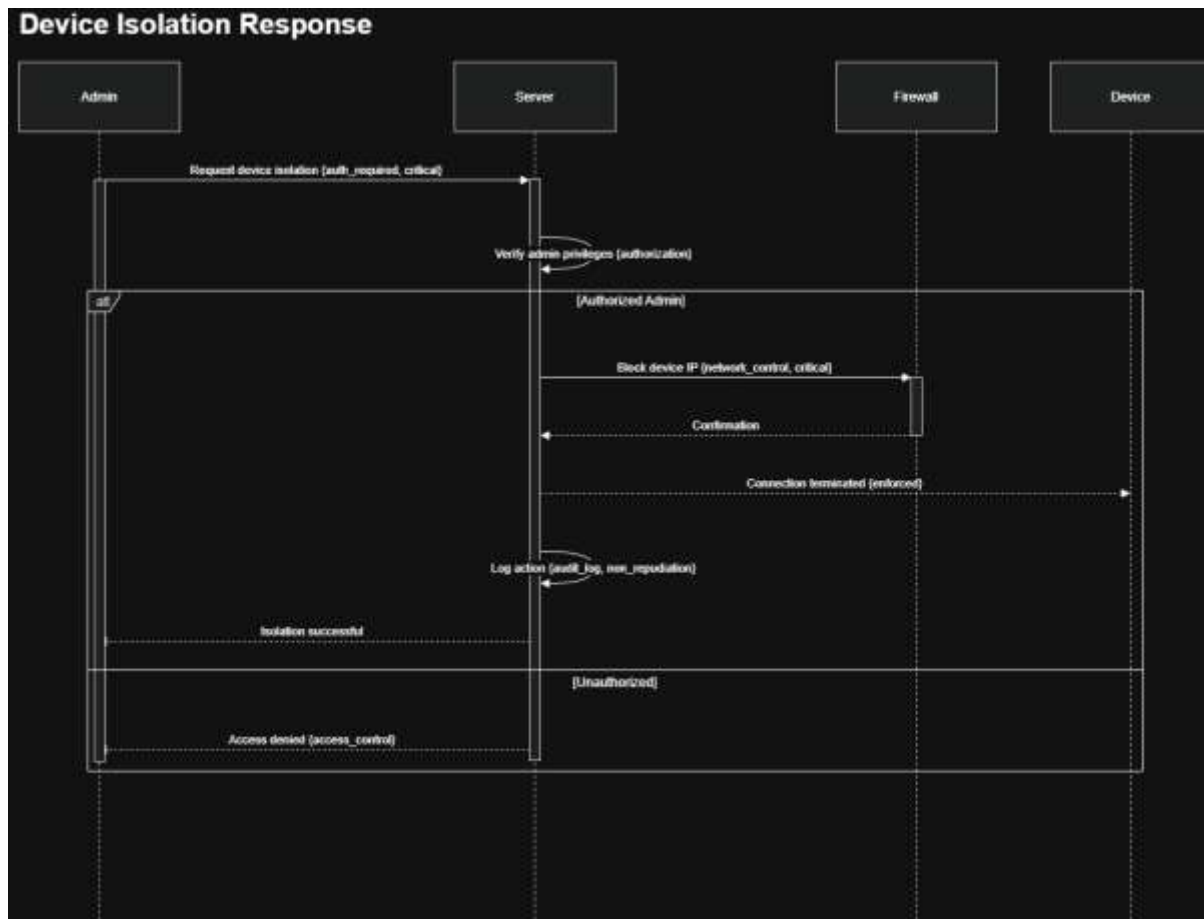
Threat Detection Process

The detection engine analyzes device data using predefined rules to identify suspicious activity. Alerts are securely logged and sent to the admin when threats are detected, while normal data is stored for monitoring and auditing.



Device Isolation Response

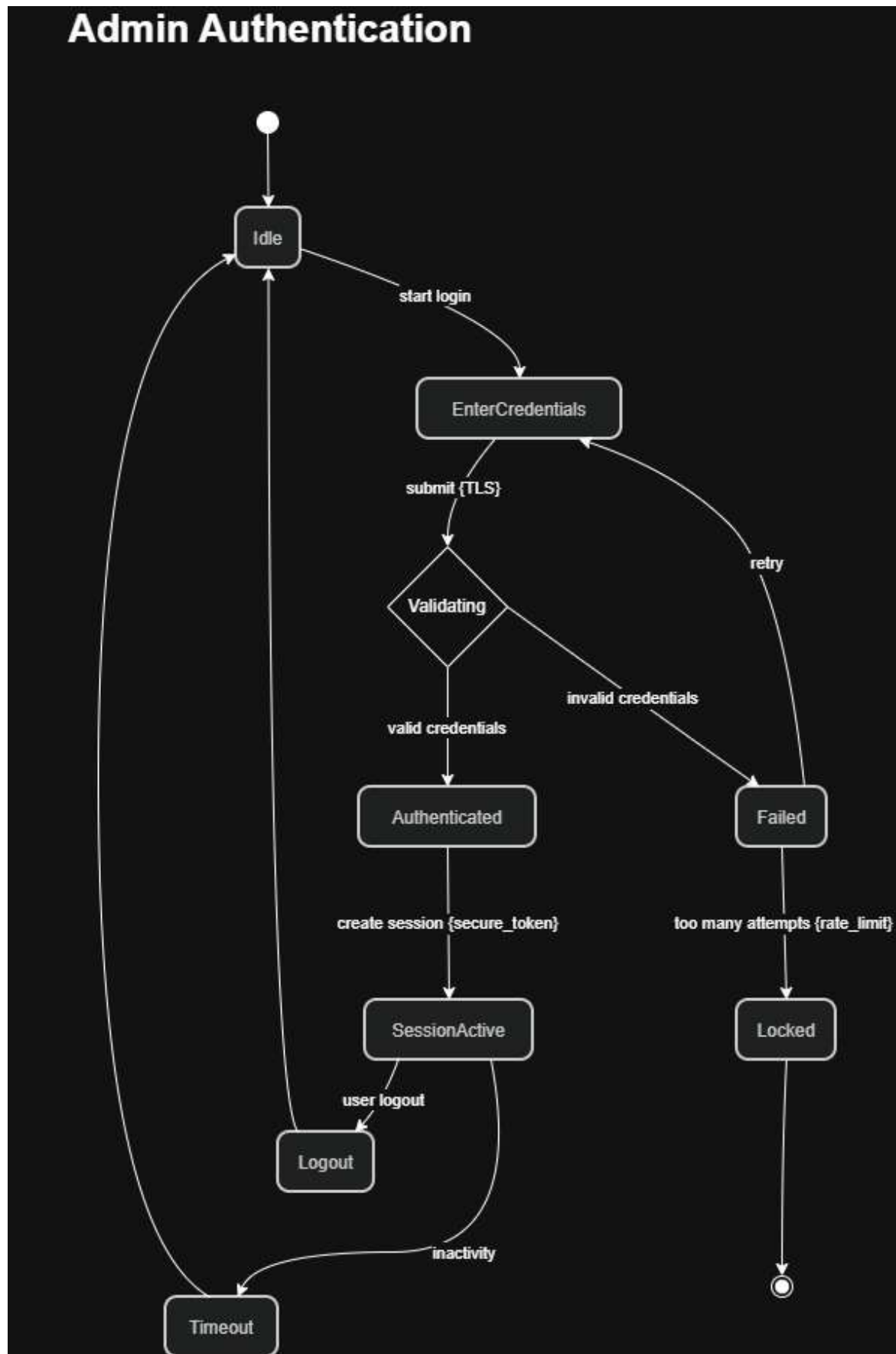
This process isolates compromised devices by blocking their network access through the firewall. Only authorized admins can perform this action, and all activities are logged to ensure accountability and prevent further attacks.



Secure Statechart Diagrams

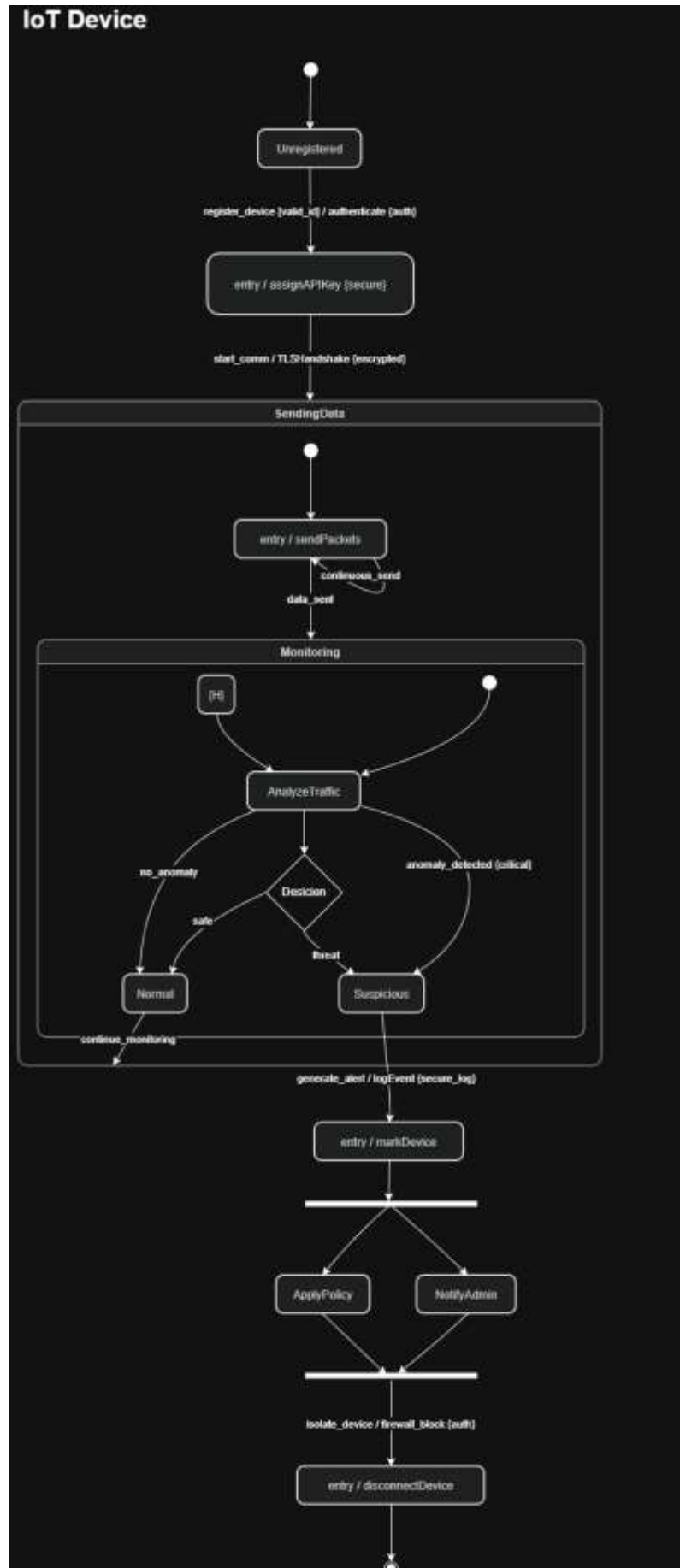
Admin Authentication

This diagram models the secure admin login process, including credential validation, session creation, and logout. Security mechanisms such as input validation, password hashing, and rate limiting protect against attacks like brute force and injection. Session management with timeout ensures protection against session hijacking, maintaining authentication and confidentiality.



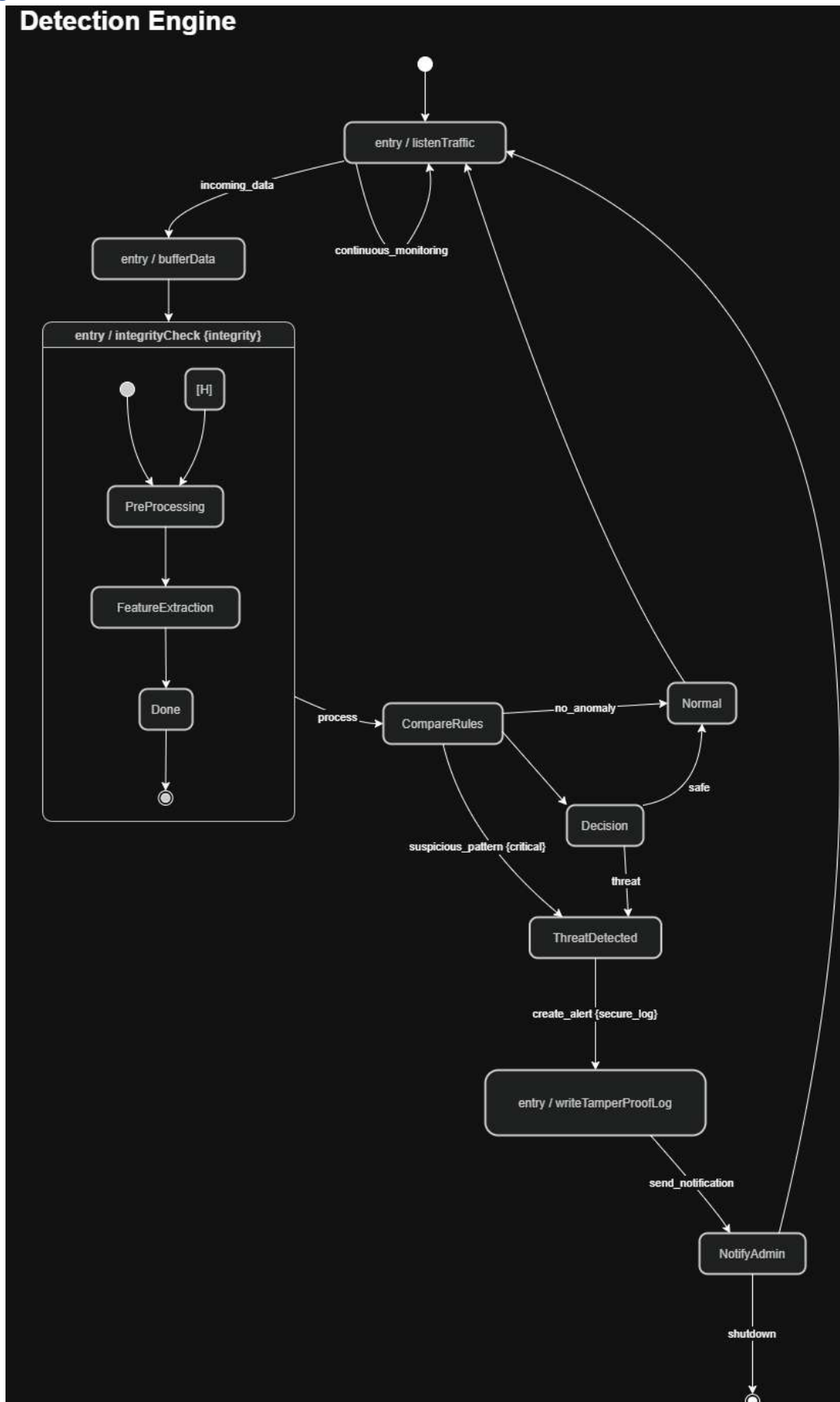
IoT Device

This statechart represents the lifecycle of an IoT device from registration to monitoring and isolation. Secure communication using TLS and device authentication prevents spoofing. Suspicious behavior triggers alerting and isolation, ensuring quick detection and containment of compromised devices.



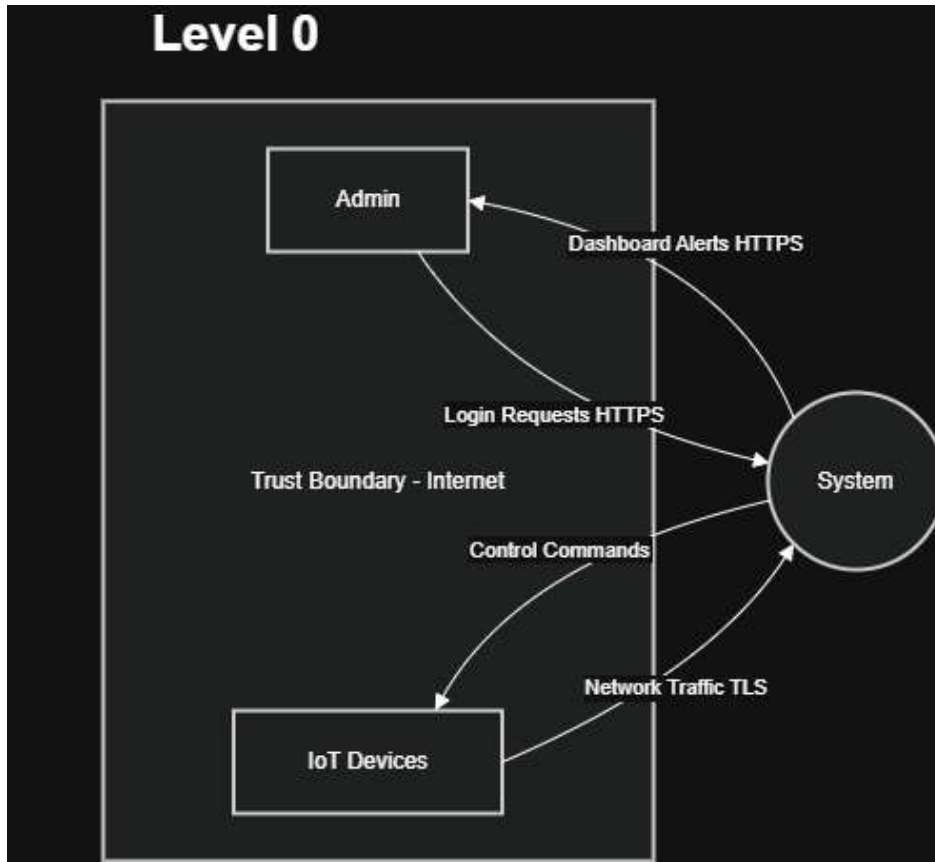
Detection Engine

This diagram shows how the detection engine processes and analyzes network traffic to identify threats. It performs integrity checks, applies detection rules, and generates alerts for suspicious activity. Secure logging ensures non-repudiation, while continuous monitoring and history state improve efficiency and consistency.

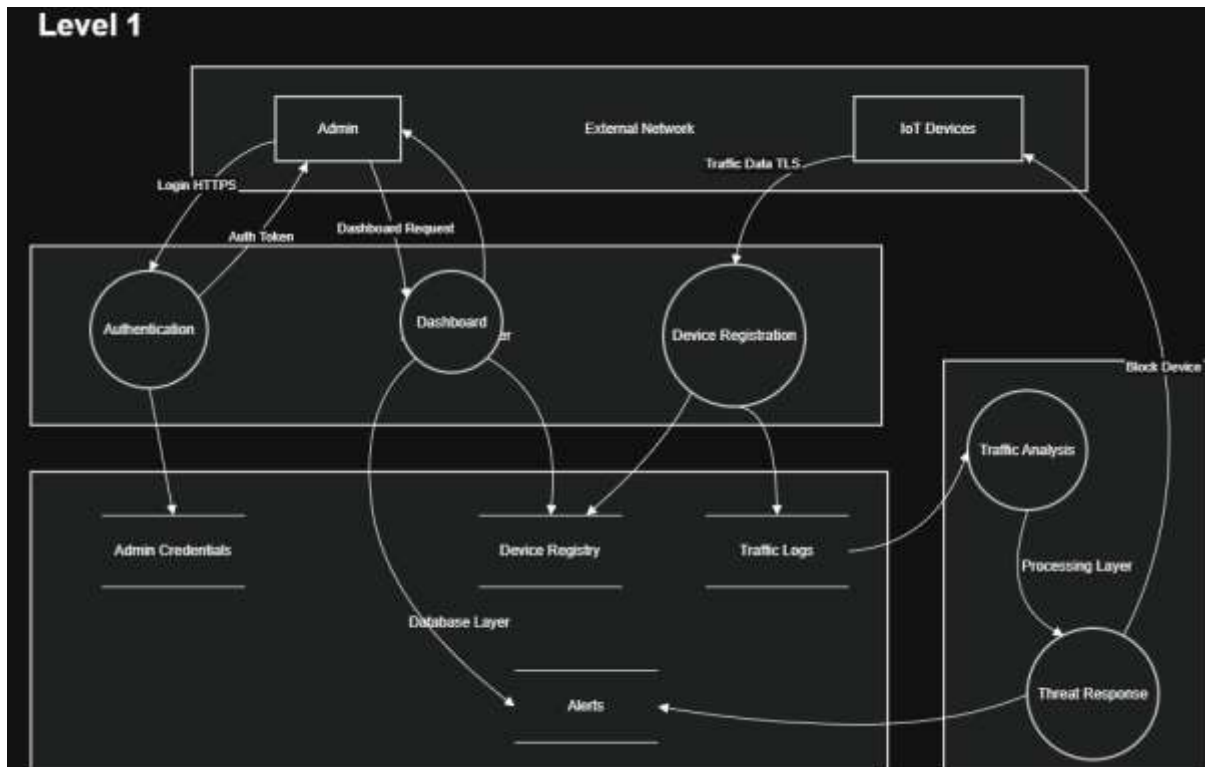


Data Flow Diagrams (DFDs)

Level 0

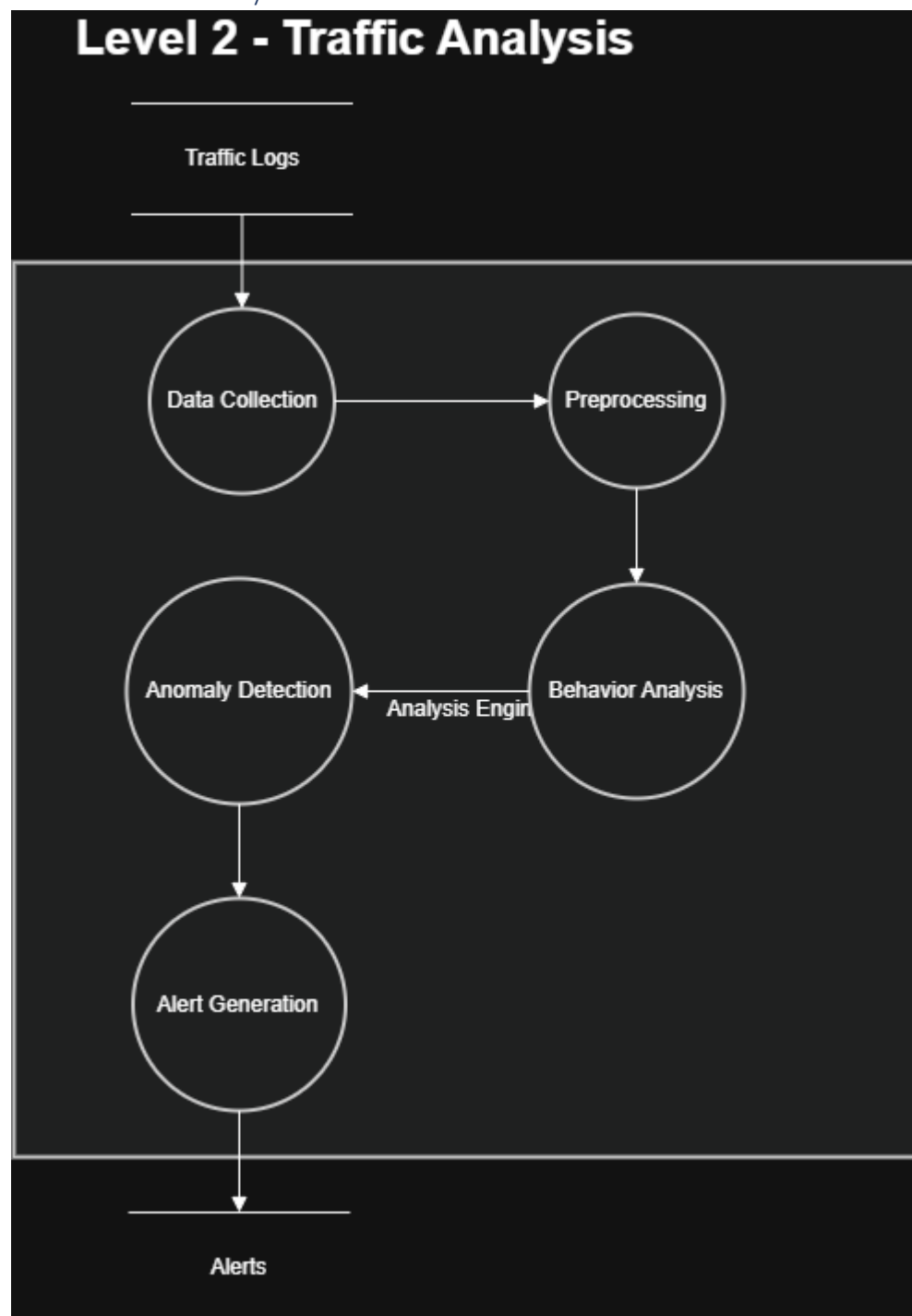


Level 1

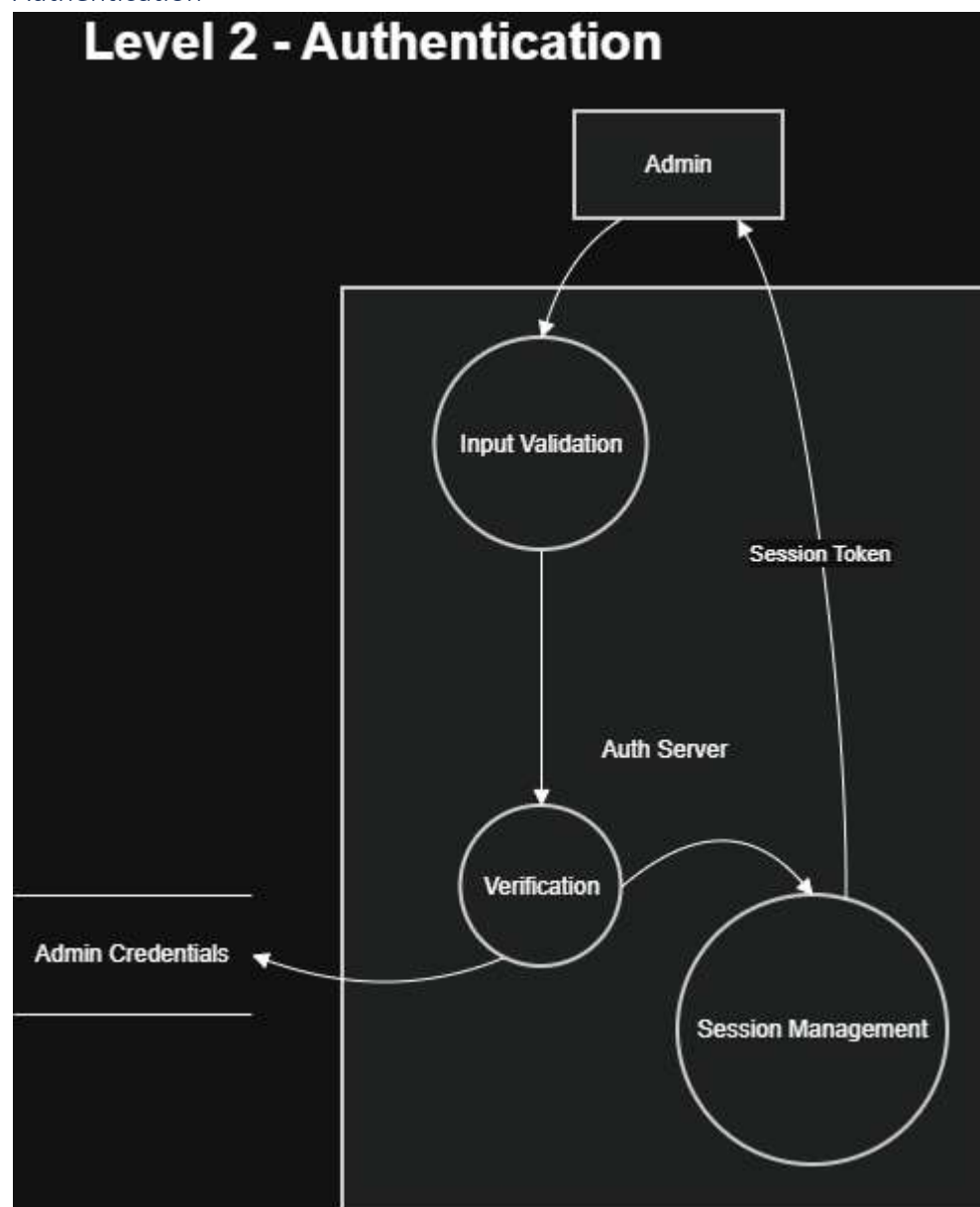


Level 2

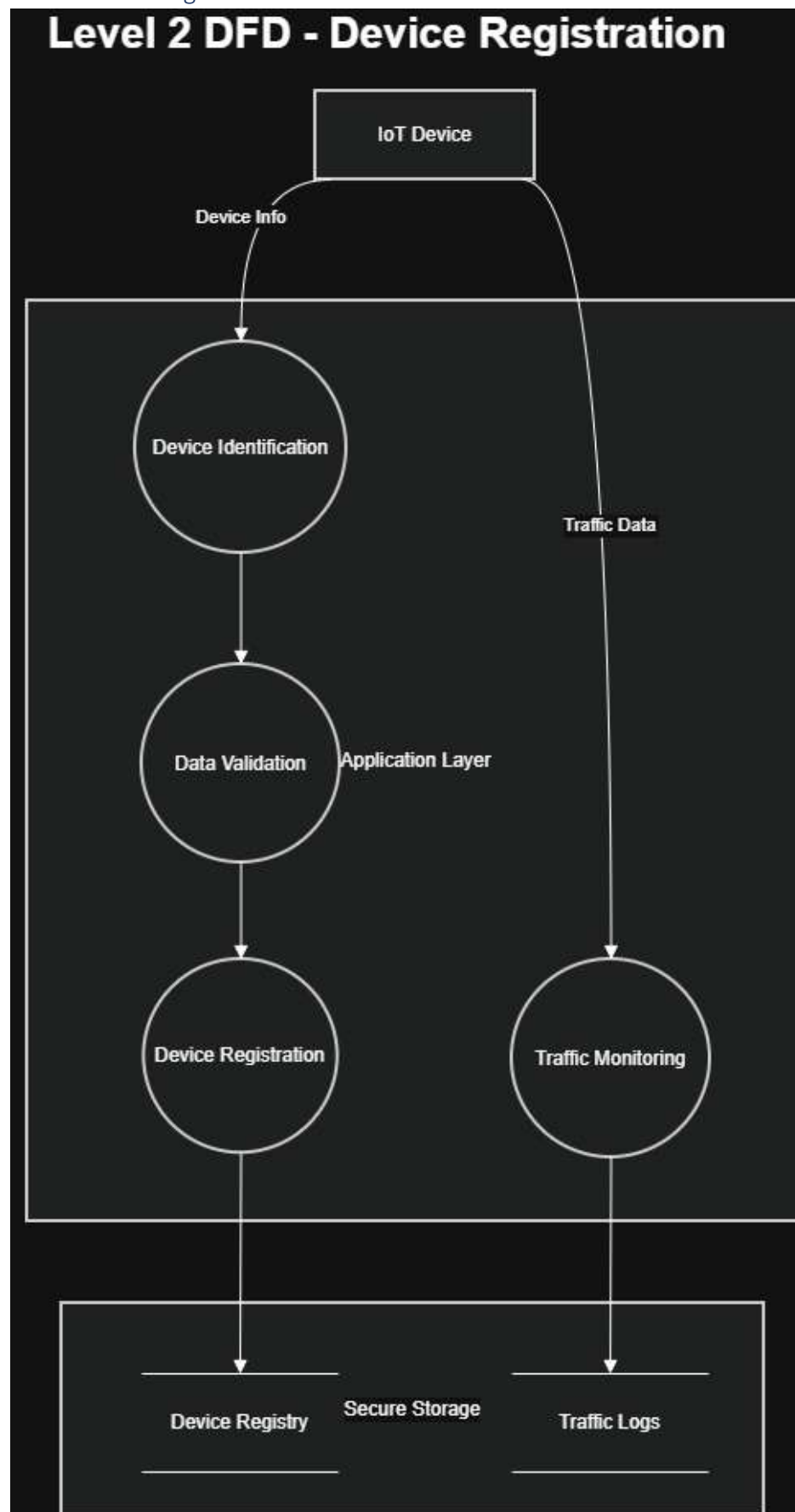
Level 2 - Traffic Analysis



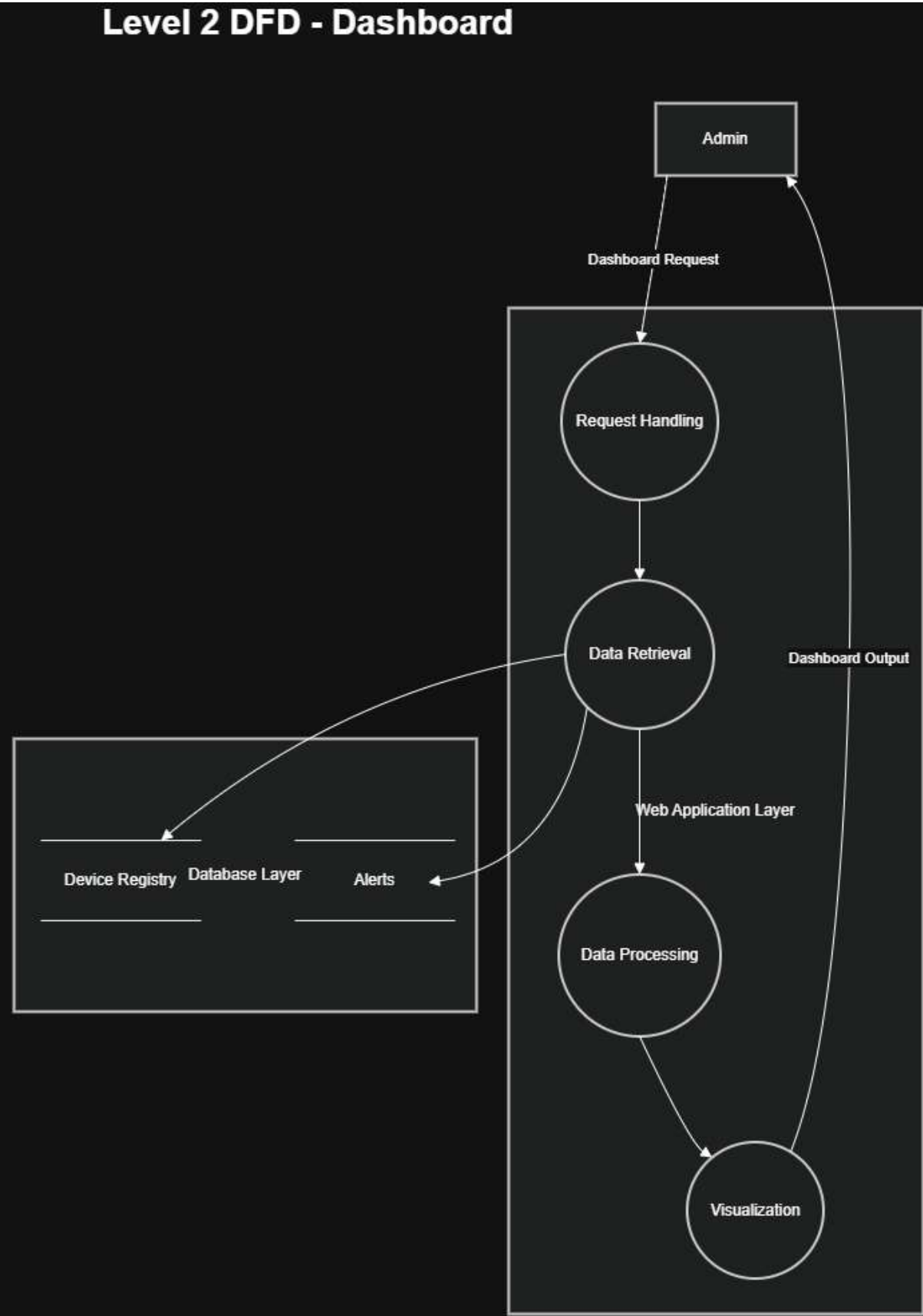
Authentication



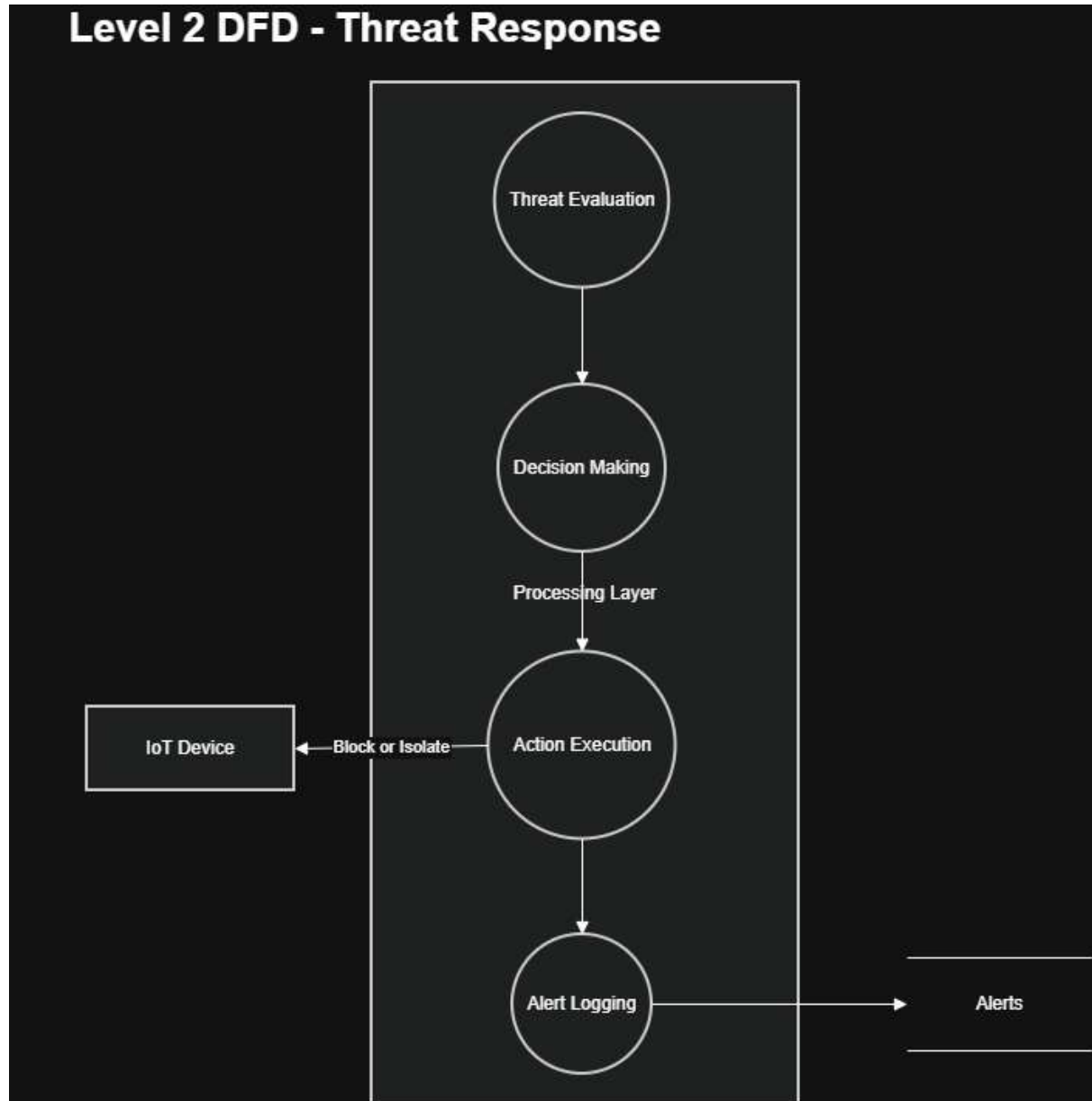
DFD - Device Registration



Dashboard



Level Response



Threat Modelling

PASTA Methodology (7 Stages)

Stage 1: Define Business Objectives & Security Goals

Business Objectives

- Monitor IoT devices for botnet activity
- Detect abnormal traffic patterns
- Provide real-time alerts to administrators
- Automatically respond to threats

Security Goals

- **Confidentiality** → Protect device and user data
- **Integrity** → Prevent tampering of traffic and logs
- **Availability** → Ensure continuous monitoring

- **Authentication** → Verify users and devices
- **Authorization** → Restrict admin actions
- **Non-repudiation** → Maintain secure logs

Stage 2: Define Technical Scope

System Components

- Web Dashboard
- Authentication Service
- Device Monitoring Module
- Detection Engine
- Response Handler
- Databases (User, Device Data, Logs)

Data Flows

- Admin ↔ Server (login, dashboard)
- Device → Server (traffic data)
- Server → Device (commands)

Stage 3: Application Decomposition

Key Entry Points

- Login API
- Device data API
- Dashboard access
- Admin control actions

Trust Boundaries

- External (Admin, IoT Device)
- Internal (Server components)
- Sensitive (Databases)

Stage 4: Threat Analysis (Attacker Profiles)

Attacker Types

- External attacker (internet-based)
- Malicious insider (admin misuse)
- Compromised IoT device

Attack Surfaces

- Login interface
- Device communication channel
- API endpoints
- Dashboard access

Stage 5: Vulnerability & Weakness Analysis

COMPONENTS	Weakness
Login System	Weak Passwords, brute force
API	Lack of input validation

<i>Device Configuration</i>	No authentication
<i>Database</i>	Unencrypted storage
<i>Logs</i>	Tampering risk

Stage 6: Attack Modeling & Simulation

Example Attack Scenarios

1. Brute Force Attack

- Attacker tries multiple passwords
- Gains unauthorized access

2. Device Spoofing

- Fake device sends malicious data
- Pollutes detection system

3. Data Tampering

- Attacker modifies traffic data
- Misleads detection engine

4. Denial of Service

- Flood system with requests
- System becomes unavailable

Stage 7: Risk Analysis & Management

Risk Mitigation Strategies

- Rate limiting → prevents brute force
- TLS encryption → protects communication
- Role-Based Access Control (RBAC) → restricts admin actions
- Input validation → prevents injection
- Logging → ensures accountability
- Firewall → blocks malicious devices

STRIDE Threat Analysis Table

COMPONENTS	STRIDE CATEGORY	THREAT	IMPACT
LOGIN SYSTEM	Spoofing	Fake User Login	Unauthorized access
LOGIN SYSTEM	Repudiation	User denies action	No accountability
DEVICE API	Tampering	Modify data	Incorrect detection
DEVICE API	Spoofing	Fake Device	System compromise
DATABASE	Information Disclosure	Data leak	Privacy Breach
DETECTION ENGINE	Tampering	Rule manipulation	Missed attacks
SERVER	DoS	Traffic flooding	Service downtime
ADMIN PANEL	Elevation of Privilege	Normal user become admin	Full system Control

DREAD Risk Scoring

Threat	Damage	Reproducibility	Exploitability	Affected Users	Discoverability	Avg Score	Priority
Brute Force Login	8	9	8	7	9	8.2	High
Device Spoofing	9	8	7	8	7	7.8	High
Data Tampering	8	7	7	8	6	7.2	High
DoS Attack	9	9	8	9	8	8.6	Critical
Privilege Escalation	10	7	6	9	7	7.8	High

Summary

The IoT Botnet Detection and Response System was designed using secure UML modeling techniques and structured threat modelling. Functional requirements were mapped to security requirements to ensure confidentiality, integrity, availability, authentication, and authorization. Various diagrams, including use case, misuse case, sequence, state chart, and data flow diagrams, were developed to represent system behavior and security mechanisms. Threat modelling was performed using the PASTA methodology, identifying potential threats through STRIDE analysis and prioritizing them using DREAD scoring. The results highlight critical risks such as denial of service, spoofing, and unauthorized access, which are mitigated through controls like encryption, rate limiting, secure authentication, and access control. Overall, the system demonstrates a secure and resilient design against common cyber threats.